Seguridad para Desarrolladores

Conceptos fundamentales para construir aplicaciones seguras y proteger tus sistemas

Made with GAMMA

Conceptos Fundamentales de Seguridad

Concepto	Definición	Ejemplo Real
Permissions	Control de qué puede hacer un usuario en el sistema	Usuario normal no puede eliminar cuentas de otros
Password Segura	Clave difícil de adivinar con longitud, símbolos y no reutilizada	"Miu@2026#Secure"
Vulnerabilidad	Falla que puede ser explotada por atacantes	No validar inputs - SQL Injection
Intrusión	Acceso no autorizado al sistema explotando vulnerabilidades	Hacker accede a base de datos
Seguridad de Red	Protección de datos en tránsito usando HTTPS, firewalls y cifrado	API protegida con SSL

Made with GAMMA

Permissions: Autenticación vs Autorización

1

Autenticación

Verificar **quién eres**

Inicio de sesión con email y contraseña

2

Autorización

Verificar **qué puedes hacer**

Solo admin puede eliminar usuarios

Diferencia clave: Autenticación = identidad • Autorización = permisos

Ejemplo en Backend

```
if (user.role !== "admin") {
  return 403; // Forbidden
}
```

Implementación

Se implementan con roles (RBAC) o reglas específicas en el backend para controlar el acceso a recursos

Made with GAMMA

Password Segura: Protección con Hashing

01

Requisitos

- Más de 8 caracteres
- Mayúsculas, números y símbolos
- No usar datos personales

02

Hashing

Convertir contraseña en texto irreversible usando funciones como bcrypt

03

Verificación

Comparar hash guardado con bcrypt.compare() en lugar de texto plano

Nunca guardar contraseñas en texto plano - Si hackean la DB, ven TODAS las contraseñas

Made with GAMMA

Vulnerabilidades: Fallas que Explotar

SQL Injection

Manipulación de consultas SQL para acceder o modificar datos

XSS (Cross-Site Scripting)

Inyección de scripts maliciosos en páginas web

Exposición de Datos

Información sensible sin protección adecuada

Ejemplo de SQL Injection

```
SELECT * FROM users
WHERE email = '' OR 1=1 -- '
```

Esta consulta devuelve **todos los usuarios** porque 1=1 siempre es verdadero

Made with GAMMA

Intrusión: Acceso Ilegal al Sistema

¿Qué Busca el Atacante?

- Datos personales (usuarios, tarjetas)
- Control total del sistema
- Ganancias económicas

Consecuencias

- Robo masivo de información
- Caída del sistema completo
- Daño reputacional severo

Made with GAMMA

Seguridad de Red: Protección en Tránsito

Qué Protege

Los datos mientras viajan por internet entre cliente y servidor

Componentes Clave

- **Firewall:** Filtro que bloquea accesos no permitidos
- **HTTPS:** Comunicación cifrada con SSL/TLS

1

Sin HTTPS

Cualquiera puede ver passwords y datos en la red

2

Con HTTPS

Datos cifrados y protegidos

Made with GAMMA

Errores Comunes en Desarrollo

No Validar Inputs

Permite inyección de código SQL, XSS y otros ataques

No Usar Roles

Sin control de permisos, cualquiera accede a todo

Exponer APIs

Endpoints sin protección permiten acceso no autorizado

Passwords Mal

Texto plano o hashing débil compromete seguridad

Consecuencia: Inyección de código, acceso no autorizado y robo de datos

Made with GAMMA

Caso Práctico: Usuario Ve Datos Ajenos

El Problema

Usuario ve información que no le pertenece - Fallo de autorización

La Causa

Permisos mal implementados, solo validación en frontend

La Solución

Validación de rol en backend con middleware de seguridad

Implementación Correcta

```
if (user.id !== data.ownerId) {
  return 403; // Forbidden
}
```

Validar siempre en backend, nunca confiar solo en frontend

Made with GAMMA

Analogía: Seguridad como Edificio

Permissions

Niveles de acceso en un edificio - diferentes llaves para diferentes pisos

Password

Llave de la puerta - única y difícil de copiar

Vulnerabilidad

Puerta abierta o cerradura rota - fácil de explotar

Intrusión

Ladrón entrando por la puerta débil

Seguridad de Red

Sistema de cámaras y alarmas - monitorea todo

Made with GAMMA